

Hot Mess Express — Data Flow & Privacy Architecture

Prepared: 2026-10-01 · **Source:** codebase audit of bear-house-classic (master)
Purpose: Plain-English technical reference for legal review (COPPA, beta agreement, liability). **Critical reading note:** Section 9 lists features that are planned but not built. Everything else describes the app as it exists today.

1. System overview

- **Client:** Web app (Vite + React + TypeScript), also packaged for Android via Capacitor.
- **API:** Serverless/edge functions hosted on Vercel (/api/*).
- **Database & Auth:** Supabase — hosted Postgres with Row Level Security (RLS), plus Supabase Auth for user accounts.
- **AI (Hermes):** Cloud inference only. Chat requests go to **Anthropic** (Claude) and/or **Google** (Gemini), using either the household's own API keys (bring-your-own) or server-configured keys. There is **no on-device AI inference** in the current build.
- **Push notifications:** Firebase Cloud Messaging (FCM).

2. Data inventory — what the app collects

Category	Examples	Notes
Account & household	Household name, member names, emails, roles, PIN hashes, colors	One households row per signup; members linked via household_members
Children	Name, role=child, optional PIN (no separate email/password required)	Children are full household members, not sub-accounts
Tasks & chores	Task text, assignee, due dates, completion state, who completed it	Core family-organizer data
Emotion logs	Person, feeling, context, intensity, category	Household-visible; Hermes is explicitly prompted to flag "low-energy emotions" proactively
Points & rewards	Point balances, reward catalog, redemptions	Per-person
Promises	Family promises, follow-through tracking	Per-user visibility for follow-through rate
Calendar/schedules	Custody schedules, events, activities	
Expenses & finance	Shared expenses, budget categories; bank connections & synced transactions (via SimpleFIN)	Bank data is per-member restricted (see §4)

Category	Examples	Notes
Health	Medication logs ("meds given" — editable only by the entering parent, viewable by both)	
Hermes memory	Free-text notes Hermes is told to remember	Household-wide by design — every device in the household sees every note
Messages (co-parent)	Co-parent messaging content	Exists in co-parenting scope
Device tokens	FCM push tokens, mapped to person	For targeted push
Co-parenting	Second household link, merge consents, custody addresses	Dual-consent required to link households
Integrations	Gmail OAuth tokens, Google Home links, Home Assistant config, camera webhooks	Optional, per-household

3. Where data lives

All persistent data is in **Supabase Postgres** (US-hosted by default). Key tables:

- households, household_members (roles: superadmin, admin, child, pet)
- family_data — flexible key-value store, household-scoped (tasks, emotions, points, etc.)
- household_memory — Hermes's shared memory notes
- household_activity — activity feed
- device_tokens — push tokens per person
- families, household_family_link — links two households in co-parent mode
- coparent_merge_consent — per-household consent records for linking
- coparent_disclosure_statutes — reference table of state address-disclosure laws (not user data)

4. Who can see what (access control)

- **Default: household-wide.** Any authenticated member of a household can read that household's data (tasks, emotions, Hermes memory, calendar, etc.). This is the current architectural assumption everywhere.
- **Two exceptions:**
- family_data.owner_member_id — rows can be restricted to one member + superadmins. Currently used for **bank connections and synced transactions only**.
- **Co-parent address confidentiality** — one parent's address/contact can be marked confidential so the linked household doesn't see it (with per-state statute references).

- **Roles:** superadmin (full household visibility incl. others' restricted rows), admin, child, pet. Children authenticate via household login; a pin_hash field supports PIN-based access.
- **Co-parent linking:** Two households join via the families table only after **both** households independently record consent (dual-consent merge). Either side can decline; no silent linking.
- **API enforcement:** Every /api/* route resolves the caller's household from their auth token and rejects cross-household access (401). Rate-limited per household.

5. AI data flows (Hermes) — what leaves our servers

Every Hermes chat sends the following to **Anthropic and/or Google** (whichever provider is configured):

1. **System prompt** assembled client-side, containing: household member names and roles, open/overdue tasks, Hermes's shared memory notes, household rules ("household brain"), and a directive to proactively flag concerning patterns (overdue tasks, broken promises, **low-energy emotions**).
2. **The user's chat messages.**

Implications for legal review: - Household data — including children's names, emotion logs, and task activity — is transmitted to US AI providers on every chat. - There is **no Business Associate Agreement (BAA)** or equivalent data-processing addendum in place with AI providers; health-adjacent data (meds logs, emotion logs) should be evaluated accordingly. - Chat content may be subject to the AI providers' own data-retention/logging policies. - API keys are either the household's own (stored per household) or server-level.

6. Push notifications

- Via **Firebase Cloud Messaging**. Notification title/body pass through Google's infrastructure.
- Two paths: household-wide broadcast (_notify.ts) and targeted per-person (notify-person.ts, resolved via device_tokens → person).
- Any text placed in a notification (e.g., a wellbeing nudge) will transit Google servers.

7. Third parties that touch user data

Party	Data	Purpose
Supabase	All database + auth data	Hosting
Anthropic / Google	Chat content + household context in system prompt	AI inference
Google (FCM)	Notification title/body, device tokens	Push delivery
Stripe	Household billing identity, subscription status	Payments (stripe_customer_id on household)
SimpleFIN	Bank credentials/tokens, transactions (per-member restricted)	Finance sync

Party	Data	Purpose
Gmail (Google OAuth)	Email metadata/content per granted scopes	Email integration
Google Home	Smart-home link tokens	Voice/device integration
Vercel	API request metadata, edge logs	Hosting

8. Children's data — current state

- Children are household_members with role=child; they can use the app via household login + optional PIN.
- **No age gate, no parental-consent flow, and no COPPA-specific handling exist in the current codebase.** A child's data (name, emotion logs, tasks, chat messages) is stored and processed identically to an adult's.
- Emotion logs and Hermes memory are **visible to every household member**, including both parents — there is no per-child private scope today.
- Chat messages from a child are sent to Anthropic/Google under the same pipeline as adults.

9. Planned but NOT built — do not review as existing

The following are design commitments for the co-parenting / kid-mode roadmap.
None of this exists in the codebase today:

- **Private child journal / private AI space** — no journal table, no per-child private data store.
- **On-device inference** (Nano-class) for journal analysis — all AI is cloud today.
- **Wellbeing nudge pipeline** (AI detecting a child "missing mom" and suggesting it to a parent) — does not exist.
- **Two-stage failsafe** (AI verifying with the child via journal questions before nudging) — does not exist.
- **Seal-and-purge** (reclassifying accidental disclosures as private and removing them from household context) — does not exist.
- **Mutual-refusal boundaries** between household Hermes and private Hermes — does not exist.
- **Parental-consent / age-gate flows** for under-13 users — do not exist.
- **Kid mode / teen mode** UI — does not exist.

10. Retention & deletion (as observed)

- Deleting a household cascades to its members, family links, and merge consents (DB-level on delete cascade).
- No explicit user-facing "delete my child's data" flow was identified in the audit; deletion today means household/member deletion via the app or support.
- AI provider retention of chat content is governed by Anthropic's/Google's policies, not ours.

11. Questions for legal review

1. COPPA: what verifiable parental-consent mechanism is required before any under-13 beta tester uses the app, given §8?
 2. Given §5, does transmitting children's emotion logs and names to AI providers without a DPA/BAA create exposure, and what mitigations (data minimization in prompts, provider selection) are advisable?
 3. For the planned nudge pipeline (§9): is a derived wellbeing suggestion ("Abriana could use extra time with mom") based on a child's journal entries a privacy violation if the journal content itself is never shown to parents? What disclosures must the child see?
 4. Beta agreement: sufficiency of "as-is / no warranty / limitation of liability / data-use consent" clickwrap for 50 families, including minors.
 5. Does the planned high-severity escalation (self-harm/abuse signals → immediate parent notification) trigger any mandatory-reporting considerations, and how should it be worded to avoid creating a duty the app cannot fulfill?
 6. State law: the app already ships a `coparent_disclosure_statutes` reference table — is surfacing statute summaries to users "legal information" vs. "legal advice," and what disclaimers are needed?
-

This document describes technical facts as observed in the codebase. It is not legal advice.